

Gestão de Serviços de Documentação Hospitalar

RICARDO BAUDEL



Unidade 4

Livro Didático
Digital



Diretor Executivo
DAVID LIRA STEPHEN BARROS

Diretora Editorial
CRISTIANE SILVEIRA CESAR DE OLIVEIRA

Projeto Gráfico
TIAGO DA ROCHA

Autor
RICARDO BAUDEL

O AUTOR

Ricardo Baudel

Olá, meu estimado aluno. Tudo bem? Meu nome é Ricardo Baudel. Sou formado em Ciência da Computação, com pós-graduações em Gestão da Informação e Metodologia da Educação a Distância. Sou mestre em Engenharia de Produção com experiência técnico-profissional na área de Tecnologia da Informação de mais de 30 anos. Atuo nas áreas de Gestão da Tecnologia da Informação, Análise e Desenvolvimento de Sistemas e Segurança da Informação, dentre as várias áreas nas quais desenvolvo minhas atividades. Acredito fortemente no papel da tecnologia como elemento transformador da humanidade. Fui convidado pela Editora Telesapiens a integrar seu elenco de autores independentes e espero que goste muito do nosso trabalho, e que o material aqui disponibilizado sirva como um importante elemento de crescimento profissional. Estou muito feliz em poder ajudar você nesta fase de muito estudo e trabalho. Conte comigo!

ICONOGRAFICOS

Olá. Esses ícones irão aparecer em sua trilha de aprendizagem toda vez que:



INTRODUÇÃO:
para o início do desenvolvimento de uma nova competência;



NOTA:
quando forem necessários observações ou complementações para o seu conhecimento;



EXPLICANDO MELHOR:
algo precisa ser melhor explicado ou detalhado;



SAIBA MAIS:
textos, referências bibliográficas e links para aprofundamento do seu conhecimento;



ACESSE:
se for preciso acessar um ou mais sites para fazer download, assistir vídeos, ler textos, ouvir podcast;



ATIVIDADES:
quando alguma atividade de autoaprendizagem for aplicada;



DEFINIÇÃO:
houver necessidade de se apresentar um novo conceito;



IMPORTANTE:
as observações escritas tiveram que ser priorizadas para você;



VOCÊ SABIA?
curiosidades e indagações lúdicas sobre o tema em estudo, se forem necessárias;



REFLITA:
se houver a necessidade de chamar a atenção sobre algo a ser refletido ou discutido sobre;



RESUMINDO:
quando for preciso se fazer um resumo acumulativo das últimas abordagens;



TESTANDO:
quando o desenvolvimento de uma competência for concluído e questões forem explicadas;

SUMÁRIO

Conceitos de qualidade em saúde 12

Conceitos de qualidade 12

Organização Nacional de Acreditação (ONA) 16

Ferramentas de qualidade..... 19

Diagrama de causa e efeito..... 20

Fluxograma 22

Folha de verificação..... 23

Segurança da informação e gestão documental..... 25

Princípios da segurança da informação..... 25

Tipos mais comuns de atacantes..... 29

Hacker ético 30

Script indie 31

Insider 31

Black hat 32

Tipos de ataque mais comuns..... 32

Denial of Service (DoS) ou ataque de negação de
serviço..... 33

Engenharia social..... 33

Sequestro de dados.....	35
Tipos de Malware mais comuns.....	35
Como agir de forma segura no uso de sistemas informacionais	36
Lei Geral de Proteção de Dados e sua relação com a gestão documental.....	39
O que é a LGPD?	39
Características da LGPD.....	41
Papéis dos agentes vinculados pela LGPD	42
Vigência e sanções.....	43
Como se preparar para implementar a LGPD	43
LGPD e a gestão documental.....	45
Sistemas informatizados para prontuários médicos	49
Sistemas de informação para saúde	49
Prontuário eletrônico.....	49

UNIDADE

04

INTRODUÇÃO

Olá, meu querido aluno. Seja bem-vindo à quarta e última unidade da nossa disciplina. Na terceira unidade, tratamos de conceitos de gerenciamento eletrônico de documentos (GED) e soluções tecnológicas para a gestão de documentos hospitalares, conceitos esses absolutamente fundamentais, cujo conhecimento é de suma importância no processo de gestão documental. Nesta unidade, veremos conceitos de qualidade, que estão diretamente ligados à gestão documental, falaremos sobre segurança da informação e sua relação com a gestão documental, falaremos dos impactos da Lei Geral de Proteção de Dados (LGPD) sobre a gestão documental. Por fim, conheceremos os sistemas informatizados para prontuários médicos e tendências tecnológicas associadas à gestão documental e hospitalar. Vamos lá?

OBJETIVOS

Olá. Seja muito bem-vindo à **Unidade 4**. Nosso objetivo é auxiliar você no desenvolvimento das seguintes competências profissionais até o término dessa etapa de estudos:

- 1.** Compreender conceitos de qualidade em saúde.
- 2.** Conhecer conceitos de segurança da informação e sua relação com a gestão documental.
- 3.** Compreender a Lei Geral de Proteção de Dados (LGPD) e sua relação com a gestão documental.
- 4.** Conhecer sistemas informatizados para prontuários médicos e tendências para o futuro.

Agora, iniciaremos mais um incrível passeio pelo mundo da gestão documental. Vamos lá?

Conceitos de qualidade em saúde



OBJETIVOS:

Ao término deste capítulo, você será capaz de entender conceitos de qualidade, tanto os aplicáveis a qualquer área como aqueles aplicáveis à área de saúde. Veremos conceitos de segurança da informação, sua relação com a gestão documental, conheceremos também a Lei Geral de Proteção de Dados (LGPD) e concluiremos vendo tendências tecnológicas para os próximos anos em gestão documental e gestão hospitalar. Vamos iniciar falando sobre qualidade na gestão hospitalar.

Conceitos de qualidade

Falar de qualidade é fácil, é um conceito que tem permeado todas as atividades. Por esse motivo, é muito importante conhecer suas características de forma mais detalhada.

A definição de qualidade vem sendo trabalhada por muito tempo. Existem várias definições informais, tais como:

- A percepção do consumidor quanto aos atributos de algo.
- Se algo tem qualidade, então satisfaz as necessidades do consumidor.
- Se algo tem qualidade, satisfaz ou supera as expectativas do cliente.

Como vimos em uma das definições informais acima, a qualidade costuma ser associada às expectativas dos clientes. Também é associada às exigências do mercado. Muitas vezes, ela está expressa nos objetivos da organização. Ganesi (1994, p. 81) afirma:

[...] Ainda que as expectativas dos clientes, em dado momento, sejam menos exigentes que suas reais necessidades, devido ao fato de nenhum dos fornecedores do serviço ser capaz de atendê-los totalmente, alguns fornecedores procurarão capacitar-se para tanto, possivelmente através de avanços tecnológicos, criando assim um diferencial competitivo. Ao longo do tempo, as expectativas dos clientes irão modificar-se, tornando-se mais exigentes à medida que mais e mais fornecedores estiverem capacitados à melhor atender às suas necessidades.

É comum ouvir dizer que a qualidade sempre está associada à excelência do produto ou serviço. E isso é bem perceptível no ambiente hospitalar. Um atendimento bem feito, dados inseridos com precisão, eficiência nos procedimentos, na forma com que o paciente é tratado – tudo remete à qualidade. E toda organização séria prioriza a qualidade, dá valor a isso. Hoje em dia não há espaço para reservas de mercado. As instituições enfrentam uma concorrência fortíssima. Porter abordou isso com maestria quando citou as forças competitivas no modelo que ficou popularmente conhecido como modelo de Porter.

Veja esse modelo na figura a seguir.

Figura 1: Força de Porter



Fonte: Elaborada pelo autor.

Conforme podemos ver nesse modelo, toda instituição sofre o efeito de forças externas continuamente. Vamos falar de cada uma delas?

A ameaça de novos entrantes acontece quando novos concorrentes chegam ao mercado. Esses concorrentes, naturalmente, buscarão tomar a posição daquela empresa no mercado. Uma forma é oferecer produtos ou serviços com maior qualidade. Mas não é somente isso. Também tem o poder de barganha dos fornecedores, que ocorre quando eles pressionam a instituição para mudar o preço dos produtos fornecidos, por exemplo. Essa pressão é ainda maior se existir alguma cláusula de exclusividade ou dependência. No caso hospitalar, por exemplo, suponha que todas as máquinas que medem a glicose (os glicômetros) tenham insumos (normalmente as fitas que coletam o sangue) que sejam apenas de um fornecedor. Então, o fornecedor resolve dobrar o preço justificando que o produto dele é exclusivo. Imaginou o tamanho do problema?

Outro problema comum é a rivalidade entre concorrentes. Os concorrentes sempre estão em busca de superar uns aos outros. Essa busca pode ser bem voraz, com uma grande disputa pelo mercado, usando de todos os recursos disponíveis. O aumento da qualidade é um desses recursos. Citando um exemplo no caso hospitalar, suponha que uma determinada rede possa fazer acordos para ser considerada rede preferencial de um dado plano de saúde. O outro ponto constante nessa figura é a ameaça de produtos substitutos. Essa ameaça é mais comum em indústrias ou empresas que fornecem algum tipo de produto. No ramo hospitalar, a troca de medicamentos de marca por genéricos é um desses exemplos. A concorrência é muito grande, e não é de estranhar que seja assim, existem muitos fabricantes nesse mercado. Por último, ainda tem o poder de barganha dos clientes, fator comum no dia a dia de qualquer instituição. Sabendo que existem concorrentes, os clientes podem pressionar dizendo que irão procurar a concorrência. Normalmente a fidelização do cliente depende muito do seu bem-estar, e de um atendimento de qualidade. Se esse atendimento não existir ou o concorrente atender melhor, o cliente vai embora sem a menor cerimônia ou qualquer peso na consciência. Vai embora e pronto.

Assim, se os procedimentos são feitos sem imperfeição – se são feitos conforme as normas, respeitando os parâmetros e se atendem aos requisitos, tendem a ser considerados como sendo de qualidade. E a qualidade é o melhor caminho para que tenhamos clientes satisfeitos. O modelo de forças de Porter que vimos anteriormente retrata bem isso. Se uma instituição tem serviços de qualidade, ela consegue fazer frente a novos entrantes, ao poder de barganha dos fornecedores, à rivalidade com outras instituições da mesma área de atuação, produtos ou serviços substitutos e ao poder de barganha do cliente, porque ele tem um diferencial competitivo fortíssimo: a qualidade.

Por isso, termos a qualidade adequada no ambiente hospitalar, é necessária uma gestão adequada – a gestão da qualidade.

Ela é baseada, naturalmente, na orientação por objetivos e, sem dúvida, na orientação pelo cliente. É para ele que as coisas são feitas. Além disso, é baseada em ferramentas que veremos mais adiante.

Toda organização tem visão e missão e a qualidade busca exatamente alcançar os objetivos e atingir as metas estipuladas. De acordo com Oliveira (2005), a visão representa um cenário ou horizonte desejado pela empresa para atuação.

Segundo Drucker (2003), uma empresa não se define pelo seu nome, estatuto ou produto que faz; porém ela se define pela sua missão. Somente uma definição clara da missão é razão de existir da organização e torna possíveis, claros e realistas os objetivos da empresa.

Segundo Carvalho *et al.* (2005), qualidade é sobrevivência. Os grandes nomes da qualidade sempre enfatizam que sem qualidade o destino natural de qualquer empresa é a extinção. A qualidade, atualmente, não é mais vista como se fosse algo separado da instituição. Antigamente havia o conceito de "pessoal da qualidade", normalmente visto como "aquele pessoal que fala em normas e ISO". Agora é bem diferente. A qualidade tem sido vista como um importante elemento integrador das diversas áreas das instituições.

Com o tempo, mudanças importantes aconteceram. O sistema de gestão passou a ser único e é considerado um sistema de gestão

da qualidade. Naturalmente, as empresas devem ter foco em atingir a qualidade de modo a se adequar aos anseios e requisitos dos seus clientes.

Vamos ver uma definição mais formal?



DEFINIÇÃO:

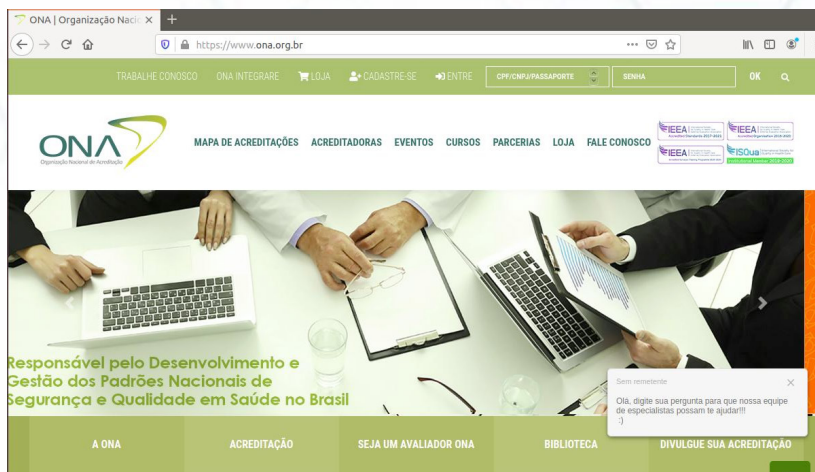
Segundo Joseph Moses Juran (1991), considerado uma das principais referências em se tratando de qualidade, qualidade é o "desempenho do produto que resulta em satisfação do cliente". No ambiente hospitalar, a qualidade está diretamente relacionada ao conceito de acreditação.

A acreditação hospitalar é considerada uma forma adequada de potencializar melhorias no gerenciamento hospitalar e, por consequência, melhoria da qualidade na assistência ao paciente. No Brasil, a criação da Organização Nacional de Acreditação (ONA), em maio de 1999, foi um passo decisivo nessa busca constante pela melhoria. A ONA é uma organização sem fins lucrativos, não governamental, que tem por missão coordenar o Sistema Brasileiro de Acreditação. Ela atua baseada em três pilares: implantação de normas técnicas e padrões, credenciamento de instituições que possam realizar a acreditação (instituições acreditadoras) e, como consequência, capacitação de profissionais que realizam as avaliações. É dela que falaremos no item a seguir.

Organização Nacional de Acreditação (ONA)

A melhor forma de começar conhecendo a ONA é vendo uma imagem do seu site, disponível em: www.ona.org.br.

Figura 2: Site ONA



Fonte: Elaborado pelo autor.

E quem é a ONA? Conforme consta no próprio *site*, ela é uma instituição que cuida do desenvolvimento e da gestão dos padrões brasileiros de qualidade e segurança em saúde. Mais de 80% das instituições acreditadas no país adotam os padrões ONA.

Por que falar em padrões?

A padronização traz várias vantagens. Traz segurança. Facilita a compatibilidade. Em se tratando de equipamentos hospitalares, a padronização também facilita a intercambialidade.

Quando falamos em padronização, naturalmente falamos em normas e normalização. São as normas que garantem que o serviço ou produto vai ter características consideradas desejáveis. O curioso é que as normas, por si, não costumam ser tão reconhecidas pelo público comum como algo relevante. Mas imagine, por exemplo, se cada fabricante resolvesse criar o próprio padrão de tomada de três pinos?

Equipamentos que não atendem às normas costumam estar fora do padrão e, portanto, trazem diversos problemas a longo prazo. Por esse motivo, naturalmente, acabam por gerar perda de qualidade.

Trabalhar conforme as normas associadas à qualidade traz diversos benefícios. Vejamos alguns deles.

Em primeiro lugar, os clientes tendem a ser fidelizados. Quando um cliente cria uma boa imagem sobre a qualidade de uma instituição, ele passa a confiar mais nela. Se um cliente pode confiar na gestão dos seus dados de paciente de uma instituição hospitalar, se ele tem certeza de que os procedimentos estão sendo realizados de forma adequada, esse cliente será fiel à instituição. Por outro lado, para a empresa, trabalhar de acordo com normas ajuda na gestão, que fica bem mais organizada e referenciada quanto ao que utilizar no seu dia a dia, quais os indicadores, limites e normatização adequada. Ter referências do que é certo é fundamental para qualquer gestão. Imagine o que seria a gestão documental sem uma norma que estabelece a tabela de temporalidade? O que seria dos documentos que não estão com a sua temporalidade definida?

No caso da ONA, não poderia ser diferente. Sua proposta é trabalhar com padrões diversos no que se refere à acreditação hospitalar. Essa acreditação é baseada em níveis, que são os seguintes: Acreditado, Acreditado Pleno e Acreditado com Excelência.

Vamos conhecer cada um deles, conforme especifica o próprio ONA.

No nível inicial (nível 1), o **Acreditado**, a instituição precisa atender ao critério a seguir: atingir ou superar, em 79% ou mais, os padrões de qualidade e segurança definidos pela ONA. Nesse nível, o certificado obtido tem validade de dois anos. Ao cabo desse período, o processo deve ser realizado novamente para que a instituição receba um certificado com nova validade de mais dois anos.

Já no nível 2, **Acreditado Pleno**, a organização precisa atender a dois critérios: cumprir ou superar, em 80% ou mais, os padrões de qualidade e segurança e cumprir ou superar, em 70% ou mais, os padrões ONA de gestão integrada, com processos ocorrendo de maneira fluida e plena comunicação entre as atividades. Da mesma maneira que no nível Acreditado, o certificado é válido por dois anos.

No nível seguinte (nível 3), que é o máximo, **Acreditado com Excelência**, a instituição deve atingir ou superar, em 90% ou mais, os padrões de qualidade e segurança; atingir ou superar, em 80% ou mais, os padrões de gestão integrada e atingir ou superar, em 70% ou mais, os padrões ONA de excelência em gestão.



SAIBA MAIS:

Quer saber mais? Acesse <https://www.ona.org.br/> e aprenda bastante sobre a acreditação hospitalar.

Já que estamos falando em qualidade, que tal conhecermos algumas das ferramentas de qualidade mais utilizadas atualmente? Então, vamos lá.

Ferramentas de qualidade

A gestão documental se relaciona, naturalmente, com ferramentas de qualidade. Conhecer essas ferramentas ajuda bastante na gestão. Vamos ver algumas delas, cujo uso é bem disseminado no dia a dia da gestão institucional.

Segundo Moura (1994), existem muitas outras, mas vamos conhecer estas três para você ter uma ideia de como elas funcionam:

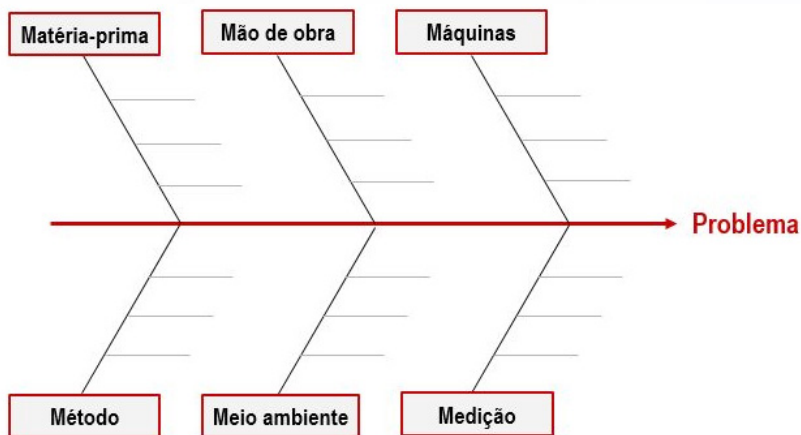
- Diagrama de causa e efeito.
- Fluxograma.
- Folha ou lista de verificação.

A proposta aqui não é abordar a fundo as ferramentas de qualidade, mas dar a você uma ideia de como são e como podem ser utilizadas na gestão

documental e em outras atividades. Vamos à primeira delas, o diagrama de causa e efeito. Esse diagrama é bastante utilizado, é bem simples de entender e o seu processo de construção também é bastante trivial e fácil.

Diagrama de causa e efeito

Figura 3: Diagrama de causa e efeito



Fonte: Elaborado pelo autor.:

Esse tipo de diagrama é fundamentado em uma proposta simples: se um problema aconteceu, o ideal para que não aconteça novamente é mapear as causas e os seus possíveis efeitos. A imagem anterior é mais apropriada a uma fábrica, mas esse diagrama pode perfeitamente ser adaptado para qualquer outro caso. O diagrama causa e efeito também é conhecido por diversos outros nomes, tais como:

- Diagrama espinha de peixe.
- Diagrama de Ishikawa.
- PDCA espinha de peixe.
- Árvore de causas espinha de peixe.

- Diagrama dos 6Ms.

Falconi (1999) demonstra que a estrutura do diagrama é similar a uma espinha de peixe, em que o eixo principal representa o fluxo de informações e as espinhas, que para ele derivam, representam as contribuições secundárias para a análise. Dessa forma, a ferramenta possibilita a visualização da relação entre o efeito e as devidas causas.

Com isso, o mais interessante dessa ferramenta é que ela parte da premissa de que todo problema tem uma causa específica, e se você eliminar a causa raiz conseguirá, por consequência, eliminar o problema. Para levantar as causas, sugere-se a realização de um *brainstorming*, do qual falaremos mais tarde. Na prática, reúne-se a equipe que levanta todas as possíveis causas, sem eliminar nenhuma inicialmente. Esse tipo de diagrama tem várias vantagens.

Por ser uma ferramenta visual, acaba tendo um uso bem simples, de fácil compreensão mesmo para quem não é da área. Além disso, as causas acabam sendo identificadas e agrupadas de uma maneira muito simples de entender. Pelo tipo de gráfico, as causas podem ser desdobradas em subcaixas, que por sua vez são depuradas até se levantar completamente as possíveis origens do problema. É fácil perceber que a própria dinâmica de construção da ferramenta é uma boa forma de gerar integração na equipe. E como ela é visual, resumida e objetiva, mantém o foco no problema principal e suas causas, deixando de fora possíveis itens que não sejam relacionados ao problema em si.

E como é feita a construção de um diagrama causa e efeito? São poucos passos, listados a seguir.

1. Defina, de forma clara e objetiva, o problema a ser analisado por sua equipe.

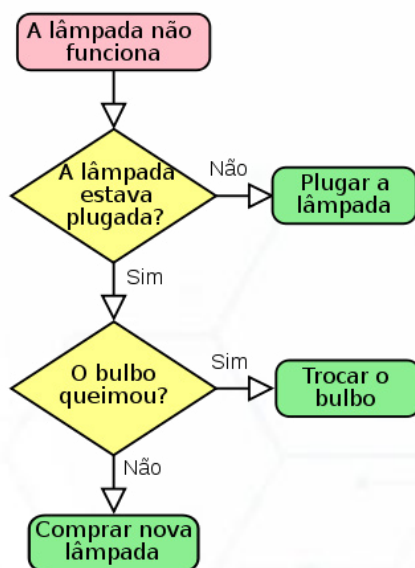
2. Desenhe, numa cartolina, numa folha ou numa ferramenta digital qualquer de computador (pode ser de desenho, mas pode ser também um simples editor de texto) uma seta horizontal que aponte para a direita e, na sua extremidade, faça um quadrado.

3. Escreva seu problema dentro desse quadrado.
4. Insira traços diagonais no corpo da seta, que serão as categorias das suas causas encontradas.
5. Realize um *brainstorming* (que é uma dinâmica em que todas as pessoas participam dando ideias e opiniões) com sua equipe para encontrar as possíveis causas.
6. Dentro das categorias definidas pela equipe, insira as causas encontradas. Com isso, é só explorar essas causas e tomar as medidas seguintes.

Fluxograma

O diagrama de causa e efeito é uma ferramenta visual, assim como uma outra ferramenta muito conhecida: o fluxograma.

Figura 4: Fluxograma



O fluxograma é um tipo de diagrama de construção bem simples, que lida com problemas, decisões, processos e fluxos. É uma representação gráfica da sequência das etapas de um processo. Sua estrutura visual permite uma análise do processo, seus fluxos e decisões tomadas. Tem um início e pode ter várias opções de finalização. Os elementos principais variam bastante de acordo com o uso, mas de uma forma geral são elipses ou retângulos definindo ações e losangos definindo decisões que precisam ser tomadas. O fluxograma tem várias vantagens: do mesmo jeito que o diagrama causa e efeito, por ser uma ferramenta visual, acaba tendo um uso bem simples, de fácil compreensão mesmo para quem não é da área. Pelo mesmo motivo, as ações e decisões acabam sendo identificadas de uma maneira muito simples e agrupadas de uma forma fácil de entender.

Vamos ver mais uma ferramenta? Essa também é muito simples: a folha ou lista de verificação.

Folha de verificação

Você já usou um *checklist* na vida? Pois é. Então, você usou uma versão da folha de verificação. Ela é uma ferramenta utilizada para organizar e apresentar os resultados de várias coletas de dados. É simples e multifacetada, pois pode ser construída em formato de quadro, tabela ou planilha.

Essa ferramenta tem múltiplos usos, desde os mais simples aos mais complexos, mesmo assim mantendo a simplicidade e facilidade de uso. Como dissemos, um *checklist*, para verificar se todos os itens de um arquivo documental estão lá, é um bom exemplo. Simples, não é?

Figura 5: Folha de verificação

Folha de verificação								
Atendimentos realizados								
turno	guichê	aten-dente	DIA					
			Seg	Ter	Qua	Qui	Sexta	Sáb
Manhã	1	A	L					
		B		C			L	
	2	A						
		B	L					
Tarde	1	C			C	F		
		D		L			M	
	2	C						
		D				L		

Fonte: Elaborado pelo autor.

Essas são uma pequena parte das ferramentas disponíveis, muito populares. Para saber mais, você pode acessar, por meio de consultas no Google, diversas páginas que mostram as mais variadas ferramentas da qualidade, tão importantes não somente na gestão documental, mas na gestão no geral.



RESUMINDO:

Podemos afirmar, portanto, que a gestão documental tem uma relação direta com a qualidade e que diversas ferramentas estão disponíveis para essa finalidade. Vamos falar agora sobre um assunto importantíssimo relacionado diretamente à gestão documental: a segurança da informação.

Segurança da informação e gestão documental



OBJETIVOS:

Na gestão documental, o principal insumo é a informação. Ela deve ser bem gerenciada, estar acessível, ser econômica, flexível e, naturalmente, segura. Ser segura significa dizer que essa informação não pode ser acessada por quem não deveria. Não deve ser disponibilizada para quem não pode ter essa informação. Esse assunto está totalmente relacionado com a segurança da informação, que conheceremos a partir de agora.

Princípios da segurança da informação

Na NBR ISO/IEC 27002:2005, a ABNT (2005) conceitua segurança da informação de duas formas: como a proteção da informação de vários tipos de ameaças para garantir a continuidade do negócio, minimizar o risco ao negócio, maximizar o retorno sobre os investimentos e as oportunidades de negócio; e como a preservação da confidencialidade, da integridade e da disponibilidade da informação. A norma diz que essa proteção pode ser obtida a partir da definição e implementação de controles adequados, que precisam ser também monitorados, analisados criticamente e melhorados para garantir que os objetivos do negócio e da segurança da organização sejam atendidos. Ainda segundo a norma, esses controles incluem políticas, processos, procedimentos, estruturas organizacionais e funções de *software e hardware*.

Com isso, atualmente, a segurança da informação tem sido considerada cada vez mais importante. Não é para menos. Diariamente, surgem notícias de casos diversos de roubo de informações, clonagem de WhatsApp, fraudes da internet. Nesse mundo cada vez mais digitalizado, estamos cada vez mais expostos.

Quem nunca ouviu em saques indevidos em contas bancárias, clonagem de cartão de crédito ou roubo de perfil em redes sociais?

Hoje você está cada vez mais conectado. Vamos citar apenas alguns equipamentos que se conectam à internet para exemplificar: *smartphones*, *smart batches*, *smart TV*, geladeiras (é, isso não é muito comum aqui no Brasil, mas é bem comum nos Estados Unidos).

Com certeza, como dissemos anteriormente, você utiliza diversos dispositivos para se conectar. Usa seu *smartphone*, seu *notebook*. Veja abaixo a imagem de uma geladeira que se conecta via Wi-Fi à internet.

Figura 6: Geladeira com internet



Fonte: Freepik

Você poderia estar se perguntando: “mas o que uma pessoa faria com uma geladeira ligada à internet? Navegar na porta?”.

A pergunta é pertinente, mas na verdade esse tipo de geladeira funciona integrada com *start matches* que têm uma lista de compras on-line. Cada vez que alguém retira algo da geladeira, por exemplo uma caixinha de leite ou achocolatado, ela passa o código de barras no sensor da geladeira, que realiza uma lista de compras que pode ser acionada pelo *start catch*. É bastante coisa interligada, não é?

Mas nem tudo é essa maravilha toda. Imagine um hacker invadir o sistema dessa geladeira e inserir mil itens na compra. Fazer uma compra caríssima e não solicitada.

É risco. Isso pode acontecer de uma forma mais fácil do que se imagina.

Agora, imagine esse mesmo risco de invasão num prontuário eletrônico. Ou num sistema qualquer de gestão documental. Já pensou um hacker apagando todos os registros históricos dos últimos 40 anos de um grande hospital? Não podemos deixar isso acontecer. É para isso que existe a segurança da informação, e a gestão documental, para funcionar a contento, depende fortemente dessa segurança.

A segurança da informação é fundamentada em princípios claros e são justamente esses princípios que são atacados pelos hackers. Aliás, o termo "hacker" é bem genérico, por esse motivo vamos esclarecer mais à frente, de forma mais específica, o que é cada tipo de ataque e atacante.

Antes, vamos conhecer os princípios de segurança da informação, que são os seguintes:

- Disponibilidade.
- Integridade.
- Confidencialidade.
- Autenticidade.
- Irrevogabilidade.

A disponibilidade está diretamente ligada ao fato de que é necessário garantir que a informação esteja sempre disponível. Esse princípio é violado, por exemplo, quando um servidor ou sistema informatizado fica fora do ar, ou seja, para de funcionar. Imagine, por exemplo, se o sistema de prontuários eletrônicos deixa de funcionar. Seria o caos, não é?

Já a integridade está relacionada com a garantia de que aquela informação não foi corrompida, ou seja, o prontuário não teve nenhuma informação alterada. Imagine o problema que seria se alguém alterasse a idade de um paciente ou retirasse as suas comorbidades da ficha de admissão? Ou se retirasse as informações sobre as alergias medicamentosas daquele paciente? É um risco que jamais deve ser corrido.

A confidencialidade, por sua vez, está diretamente relacionada ao acesso à informação. Existem informações que são sensíveis (falaremos mais delas quando, mais à frente, falarmos sobre LGPD, ou Lei Geral de Proteção de Dados) e jamais podem ser acessadas por quem não deveria (no jargão da segurança, dizemos que essa informação foi "vazada"). O vazamento de informações causa problemas gravíssimos, com grande repercussão. Lembra de casos onde os dados de cartão de crédito, como número, código de segurança e senha foram vazados em *sites* de jogos, causando um problema de enormes proporções?

Para Salvador e Almeida Filho (2005), embora os códigos de ética dos profissionais de saúde exijam o sigilo e a privacidade das informações sobre os pacientes, a má utilização da Tecnologia da Informação tem facilitado o extravio, o acesso e a alteração indevidos. Por isso, existe uma necessidade clara de proteger os sistemas e bancos de dados utilizados nos hospitais, nos quais são armazenadas informações cujo sigilo é obrigatório. Muitos desses sistemas e bancos de dados estão acessíveis e disponibilizados nas redes de computadores dos hospitais, que facilitam o acesso para quem analisa e alimenta esses dados, mas aumentam a possibilidade de acesso por pessoas não autorizadas, seja intencional ou não.

Um prontuário, por exemplo, jamais pode ser vazado ou ser acessado por pessoas que não têm autorização para isso.

Por outro lado, também é muito importante garantir que uma determinada informação tenha sua legitimidade garantida. Esse é o princípio da autenticidade, que busca assegurar a veracidade da fonte anunciada e de que a informação não sofreu nenhum tipo de modificação.

Por último, vamos conhecer o princípio da irrevogabilidade. Ele garante que quem fez alguma operação, alterou um dado, não pode negar que o fez. Por exemplo: se alguém altera uma prescrição de um tratamento em um sistema informatizado, o sistema grava um registro com a operação feita. Normalmente isso é feito em arquivos chamados de log.

Esses princípios são fundamentais. Se algum deles é atingido, toda a confiabilidade do sistema vai por água abaixo.

Imagine, por exemplo, um sistema informatizado que fica indisponível por duas horas. Quando volta, percebe-se que diversos dados e registros importantes foram perdidos.

Normalmente, quando há um problema ou, mais tecnicamente falando, uma ocorrência ou um incidente de segurança, toda a confiança no sistema passa a estar seriamente abalada e são diversos os tipos de ataque que podem gerar problemas assim.

Por isso, as pessoas que trabalham com sistemas informatizados devem ter noção básica dos possíveis ataques e atacantes que existem nesse mundo da segurança da informação. Além disso, também é importante saber se prevenir contra esses problemas.

Vamos falar agora dos possíveis atacantes e das ameaças e depois falaremos das medidas de segurança mais comuns que podem ser tomadas por qualquer usuário.

É bastante comum ouvirmos falar no termo "hacker". Mas você sabia que existem vários tipos de hacker e que o que é destrutivo é o *cracker*, e não *hacker* simplesmente?

Tipos mais comuns de atacantes

A Cartilha de Segurança para Internet (2006) é um documento com recomendações e dicas para a utilização e segurança na internet. De acordo com essa cartilha, ataques costumam ocorrer na internet com diversos objetivos, visando diferentes alvos e usando variadas técnicas.

Qualquer serviço, computador ou rede que seja acessível via Internet pode ser alvo de um ataque, assim como qualquer computador com acesso à internet pode participar de um ataque.

É muito comum considerar todo invasor um *hacker*. Mas esse termo genérico não cobre, de fato, os tipos existentes. Nem todo *hacker* é maldoso. Existe, por exemplo, o *hacker* ético, que atua buscando falhas nos sistemas para poder recomendar possíveis formas de sanar a falha e evitar o perigo. Vamos começar falando dele.

Hacker ético

Nos primórdios da informática, mais especificamente no começo da internet, já se falava em *hacker*. Apesar de ter como referência o verbo em inglês "too hacker", a ideia por trás desse termo era vinculada a pessoas que buscavam achar falhas em sistemas tecnológicos.

Mais especificamente, o *hacker* tenta explorar e detectar erros em sistemas computacionais, usando para isso seu conhecimento tecnológico. Nesse tipo de trabalho, o *hacker* ético busca encontrar falhas e propor soluções. Mas, infelizmente, o termo tem seu significado distorcido atualmente. Quando se fala em *hacker*, é sempre para imaginar aquele bandido digital que está por trás de invasões buscando destruir dados e prejudicar pessoas, com fraudes diversas ou exposição de dados pessoais.

Em razão dessa mistura de conceitos, hoje em dia se fala em "*hacker* do bem" e "*hacker* do mal".

Mas na verdade existem vários tipos de *hacker* e a classificação normalmente é feita com base em seus conhecimentos técnicos, que vão desde os básicos, que são aqueles conhecidos pelos *scripts* cidades; até os mais sofisticados, que atuam na busca de vulnerabilidades para corrigi-las e evitar invasões.

O *hacker* ético, ou popularmente conhecido como White Hat, trabalha no sentido de proteger e prevenir os ataques. Normalmente esses

ataques partem de usuários com pouco conhecimento em segurança, mas que mesmo assim tentam invadir redes. Esses usuários são os *scripts* cidades.

Script indie

Esse tipo de *hacker* é caracterizado pelo pouco conhecimento em segurança da informação. Normalmente, ele usa ferramentas disponíveis na própria internet para realizar os ataques. É facilmente detectado e sempre deixa rastros de suas invasões. Em um sistema de gestão documental, o *script* cidade normalmente é aquele cliente ou pessoa de fora que tenta, de alguma forma, ter acesso aos documentos e, se puder, altera ou rouba esses documentos. Um sistema bem protegido dificilmente é atingido pelos *scripts* cidades.

Por outro lado, existem atacantes que nem estão fora da empresa – estão dentro. Esse é o *insider*, do qual trataremos a seguir.

Insider

Em muitas situações, o *insider* é considerado um dos piores tipos de *hackers* existentes. Ele, como o próprio nome diz, está dentro da própria empresa. Imagine o que poderia acontecer se um funcionário de uma rede hospitalar, enfurecido com alguma advertência que recebeu, resolvesse alterar por conta própria prontuários de pacientes? Ou pior, apagá-los do sistema.

Isso poderia ser feito, por exemplo, se alguém conseguisse descobrir o usuário e a senha de algum colega – ou mesmo se descobrisse alguma falha no sistema.

O *insider* é naturalmente perigoso porque tem informações privilegiadas que permitem a ele realizar ataques de grande vulto, simplesmente por ter essas informações diferenciadas. Ele pode, por exemplo, repassar informações sobre atendimentos, faturamento ou

outros dados relevantes para a concorrência, gerando um claro problema de vazamento de informações oriundo de dentro da própria instituição.

Por isso, qualquer sistema de gestão documental deve registrar internamente tudo o que os usuários fazem, para que qualquer movimentação ou operação não prevista seja rastreada e, em caso de se identificar que a operação é ilegal, ilícita ou não permitida, que as decisões sejam tomadas com base em informações sólidas do sistema.

Black hat

Esse tipo de invasor é o que mais se confunde atualmente com o significado de *hacker*. Na prática, contudo, ele não é um *hacker* – é um *cracker*. Ele usa os conhecimentos avançados que tem para atacar o sistema e tirar vantagens disso, normalmente de ordem financeira.

Para isso, inserem vírus que bloqueiam o acesso ao computador, como os *Ransomwares* (veremos isso mais tarde), ou realizam ataques de negação de serviço, conhecidos como DoS (*Denial of Service*). Esse tipo de *hacker* é, tecnicamente, o criminoso.

De toda forma, sempre há a possibilidade do black hat se converter e passar a atuar como *hacker* ético.

Já que falamos em alguns tipos de ataque, que tal conhecermos agora os tipos de ataque mais comuns em sistemas informacionais?

Tipos de ataque mais comuns

Existem vários tipos de ataque, desde os mais simples até os mais graves, nos sistemas de informação. Vamos conhecer alguns deles.

Vamos iniciar por um que é bem conhecido: o ataque que “tira o sistema do ar”. Tecnicamente ele é conhecido como “ataque de negação de serviço”.

Denial of Service (DoS) ou ataque de negação de serviço

De acordo com a Cartilha de Segurança para Internet (2006), como o próprio nome diz, o ataque de negação de serviço é um conjunto de procedimentos que tem por finalidade fazer milhares ou milhões de requisições a um servidor de sistema até que ele fique completamente sobrecarregado, ou seja, torne-se incapaz de responder às solicitações dos usuários. Quando um ataque desses é bem-sucedido, ele faz com que o sistema "saia do ar", ou seja, fique indisponível.

Esse tipo de ataque é feito disparando requisições espalhadas por vários computadores infectados com vírus, que muitas vezes nem sequer os donos sabem que eles estão infectados. É um ataque sofisticado, que demanda conhecimento de programação, de redes de computadores e de sistemas operacionais. Já o ataque que veremos a seguir não depende tanto de conhecimentos técnicos profundos, mas da capacidade do meliante de confundir e explorar fragilidades do comportamento humano. Esse ataque é chamado de engenharia social.

Engenharia social

Ainda conforme a Cartilha de Segurança para Internet (2006), o termo é utilizado para descrever um método de ataque, em que alguém faz uso da persuasão, muitas vezes abusando da ingenuidade ou confiança do usuário para obter informações que podem ser utilizadas para ter acesso não autorizado a computadores ou informações.

Suponha que um *hacker* quer invadir um sistema de gestão documental de uma instituição. Ele não quer tirar o sistema do ar, ele quer acesso ao que está lá.

Ele sabe, contudo, que um determinado funcionário tem esse acesso. Qual seria a melhor forma de conseguir isso sem ser percebido? Acessando o sistema com o *login* (usuário) e senha dessa pessoa.

Já que ele sabe que não vai conseguir essas informações perguntando, então ele usa meios para enganar a pessoa que tem esse acesso. De que forma? Usando técnicas de persuasão, que vão desde um falso *link* enviado pelo WhatsApp ou um "phishing" (falaremos mais dele à frente) enviado para a sua conta de e-mail.

Os *hackers* que usam engenharia social são arditos. Eles usam todos os artifícios possíveis para conseguir informações sobre aquele usuário.

Nessa busca, vasculham redes sociais, enviam falsas mensagens de e-mail e buscam qualquer informação que seja relevante e possa dar um caminho de qual seria o usuário e senha daquela pessoa. Pense bem: numa rede social as pessoas costumam colocar nome completo, data de aniversário, nome de filhos, onde trabalham, o que gostam de fazer, nomes de esposos, esposas, companheiros, namoradas etc. Além disso, colocam datas importantes, locais por onde passaram, preferências pessoais etc.

São dados que se configuram como um verdadeiro presente para os *hackers*. Explorados corretamente, esses dados podem ser muito úteis para roubar credenciais de acesso.

Suponha que o usuário-alvo gosta de um determinado time de futebol e colocou isso nas suas redes sociais. O *hacker* pode enviar um e-mail a esse usuário e induzi-lo a clicar em um falso *link*, alegando que ele poderia ganhar ingressos para uma determinada partida se fizesse um "cadastro".

Nesse cadastro, a pessoa deveria informar um e-mail e cadastrar uma senha. Como normalmente as pessoas tendem a usar as mesmas senhas em vários locais diferentes, há uma alta probabilidade dessa senha que foi obtida no falso cadastro ser a mesma que o usuário mantém no seu dia a dia para diversos sistemas. Com o usuário e essa senha, o *hacker* faz a festa.

A engenharia social funciona assim. Desvia a atenção do usuário para que ele forneça dados importantes sem sequer saber que está fazendo isso.

Um outro tipo de ataque sequestra máquinas colocando senhas e exigindo resgate dos donos. É sobre o ataque por *Ransomware* que vamos falar agora.

De acordo com o site "Brasil, país digital", ***Ransomware*** "é um tipo de golpe virtual no qual os criminosos cibernéticos usam programas maliciosos para tornar inacessíveis seus dados armazenados no seu computador, dispositivo".

Sequestro de dados

O sequestro de dados é um ataque altamente lesivo e tem sido bastante comum. No ataque do vírus WannaCry, centenas de hospitais da Inglaterra tiveram suas máquinas sequestradas e foi exigido resgate.

Nesse tipo de sequestro, as máquinas são infectadas por um vírus que criptografa o computador e impede que os dados sejam lidos. Para fornecer a chave que desbloqueia os arquivos daquela máquina, o sequestrador cobra um resgate em bitcoins.

Esse tipo de ataque tem sido bastante comum e ainda demanda muita atenção dos fabricantes de antivírus para tentar mitigar os danos ocorridos. Mais adiante falaremos como se prevenir desse tipo de ataque.

Grande parte desses ataques é feito utilizando programas prejudiciais de computador, conhecidos como Malwares. É deles que iremos falar agora.

Tipos de *Malware* mais comuns

Conforme dissemos anteriormente, diversos são os tipos de ataques realizados. Em muitos casos, são utilizados programas maliciosos de computador, comumente conhecidos como vírus (CERT.BR).

Mas o que são vírus de computador? São programas utilizados para infectar máquinas e causar danos, que podem ser desde apagamento de dados até a sua cópia não autorizada.

Existem vírus que são embutidos em outros programas, chamados de Cavalos de Troia ou *Trojan Horses*.

Também existem os Spywares, que são vírus que rastreiam o tráfego do usuário e podem enviar publicidade não autorizada ou desviar esses dados para *hackers*.

O Ransomware, que citamos anteriormente e sequestra dados de computadores, também é um desses tipos de malware. É importante saber se prevenir contra esses problemas. É disso que falaremos no item a seguir.

Como agir de forma segura no uso de sistemas informacionais

Existem algumas regras simples que, se você as seguir, pode se proteger de uma forma mais eficaz contra os problemas relacionados à segurança dos sistemas informacionais (CERT.BR).

São diversas as dicas para se prevenir, seja no trabalho, em casa ou na rua. A segurança não se faz apenas com senhas em equipamentos, mas no seu próprio comportamento. Abordaremos algumas regras básicas de segurança aqui.

Regra 1: Seu crachá, *login* e senha são intransferíveis, só seus. Não empreste de jeito nenhum. Não ceda nenhum dispositivo de acesso a outras pessoas, não importa quem seja. Tudo o que for feito com essas credenciais de acesso será de sua responsabilidade. Não dê moleza nesse tipo de situação.

Regra 2: Proteja suas senhas. Jamais coloque senhas embaixo de teclado, na frente do monitor, dentro de uma gaveta ou anotada em algum lugar. Nunca, nunca deixe a senha escrita em local de fácil acesso.

Regra 3: Não guarde senhas em documentos que podem ser acessados por outras pessoas.

Regra 4: Computador não é brinquedo. Se seu computador está apresentando um comportamento estranho, avise o pessoal do suporte. Pode ser vírus ou ele pode ter sido invadido por um *hacker*. Desconfie sempre.

Regra 5: Não clique em *links* que oferecem coisas de graça que você nunca pediu. Não existe almoço grátis. Aquele *link* pode estar captando dados que, no futuro, podem ser usados para invadir o seu próprio sistema de gestão documental e apagar tudo. Nesse caso, você fica em maus lençóis.

Regra 6: Nunca use aparelhos piratas para captar sinal de tv por assinatura sem pagar. Esses aparelhos são extremamente perigosos. Normalmente eles têm um programa oculto que tem acesso ao tráfego de rede da sua residência e podem ler seus dados, como senhas, usuário, dados bancários. Além de captação de sinal ilegal ser crime, os riscos são enormes, tanto de perda de dados como de responsabilização criminal. O barato pode sair caro, muito caro.

Regra 7: Desconfie de coisas que você não solicitou. Nesse tipo de situação, não aceite sob nenhuma hipótese. Tem sido bem comum o golpe das falsas chamadas informando que "o seu equipamento de tv por assinatura precisa ser atualizado".

Regra 8: A clonagem de WhatsApp é cada vez mais comum para golpes em que *hackers* pedem dinheiro. Nunca, nunca forneça código nenhum de WhatsApp para ninguém.

Regra 9: Nunca use Wi-Fi desconhecido, como o de restaurantes, para navegar na internet. O sistema pode estar configurado para levar você a um falso site, coletando seus dados. Em qualquer caso, verifique se o endereço na parte superior do site é correto.

Regra 10: Nunca entregue *smartphone*, *notebook*, *tablet* ou qualquer equipamento seu na mão de estranhos. Jamais.

Regra 11: Nunca crie senhas fáceis. Senhas como 12345678 são fáceis de adivinhar e, por esse motivo, são inúteis. Use uma senha fácil de lembrar e difícil de adivinhar.

Seguindo essas regras, você terá uma atitude segura e poderá utilizar seus equipamentos de forma mais tranquila.



RESUMINDO:

Vimos, neste capítulo, a importância da segurança da informação no uso adequado dos sistemas informatizados, tanto os tradicionais quanto os de gestão documental. Essa postura cuidadosa é absolutamente fundamental para que se possa garantir a segurança da operação diária desses sistemas.

No próximo item, veremos a importância do cuidado com os dados dos usuários que está sendo implantada com a Lei Geral de Proteção de Dados (LGPD).

Lei Geral de Proteção de Dados e sua relação com a gestão documental



OBJETIVOS:

No dia a dia do uso dos sistemas informacionais, lidamos com dados que são extremamente importantes. No Brasil está entrando em vigor uma lei muito importante: a Lei Geral de Proteção de Dados (LGPD), que impactará a gestão de dados de qualquer sistema computacional. O sistema de gestão documental, por ser um sistema computacional, também se sujeitará a essa lei.

O que é a LGPD?

A LGPD é um marco em relação à regulamentação da política de uso de dados. Ela busca, inicialmente, estabelecer parâmetros para garantir a privacidade das pessoas.

Atualmente, a internet é vista como “terra de ninguém”. Para piorar, as pessoas fornecem seus dados em todo lugar. Quer ver um exemplo? Muitas vezes, quando você vai a uma farmácia, seu CPF é solicitado para que você ganhe descontos. Bem, ao menos essa parece ser a intenção. E você faz um pequeno cadastro em que coloca (na maioria dos casos) CPF, RG, nome, data de nascimento, plano de saúde, endereço, telefone, e-mail, isso só para citar os mais comuns. E ainda informa se deseja receber promoções.

Pronto! Seus dados estão nas mãos de estranhos. Aí surgem a perguntas: quem vai ter acesso a esses dados? Essa pessoa vai repassar esses dados a alguém ou a alguma outra empresa? O que essa outra empresa vai fazer com seus dados? Quem garante que esses dados não serão vazados para pessoas mal-intencionadas? Se aquela empresa falir, o que será feito desses dados? Onde esses dados estão armazenados? Aqui no Brasil ou fora?

Pois é. Seus dados estão por aí, na mão de gente que você nem conhece, armazenados em locais que você não sabe onde é consultado por pessoas que você não tem a menor ideia de quem sejam e nem o que querem fazer com seus dados.

Foi por casos assim que surgiu a LGPD. Essa “terra de ninguém” precisa ser regulamentada.

Vamos imaginar um outro caso. Suponha que você precisou fazer uma cirurgia de emergência em um hospital. Estava jogando futebol e quebrou o pé. Imediatamente, procurou socorro médico. Foi ao hospital. Qual é a primeira coisa a ser feita? A ficha de admissão do paciente.

Nela, diversos dados são inseridos, muitos deles parecidos com os que você inseriu no exemplo da farmácia acima. Mas tem um porém: nesse cadastro, também são informadas comorbidades; doenças, como hipertensão, diabetes e diversas outras.

Então, num certo dia, aquele hospital decreta falência. Os dados estão armazenados lá e passam a ser gerenciados pelo gestor da massa falida. Todos os funcionários são demitidos e os dados ficam lá, sem que ninguém seja responsável por eles.

E agora? Seus dados estão em computadores cujo acesso não é controlado, podendo inclusive serem vendidos para outras empresas com seus dados dentro deles. Seus dados agora estão totalmente à deriva, podendo ser acessados por qualquer pessoa que tiver contato com aquela máquina. É um grande problema de privacidade, seríssimo.

Imagine se nesses dados tiver o seu número de cartão de crédito? E se esses dados caírem na internet sem que você saiba? Um perigo, não é?

A LGPD tem, portanto, a proposta de estruturar e regulamentar o funcionamento e a operação das organizações a partir do estabelecimento de regras absolutamente claras sobre coleta, armazenamento, tratamento e compartilhamento de dados pessoais. Acabou a “terra de ninguém”.

Agora, não é simplesmente pedir os dados e pronto. A coleta e o processamento desses dados devem acontecer de acordo com o que

estabelece a lei. O que essa lei evidencia são as hipóteses em que esses dados são coletados: sob consentimento e com real interesse.

Significa dizer que o usuário deve conceder, de forma explícita, essa autorização de coleta de dados a quem o fará, que é chamado de controlador.

Por sua vez, o controlador deve expressar qual é o seu legítimo interesse nesses dados, considerados a partir de situações concretas, e não simplesmente alegando que é "porque quer". Tudo agora ficam bem mais definido. Vamos ver com mais detalhes as características da LGPD.

Características da LGPD

De acordo com a Lei nº 13.709, de 14 de agosto de 2018, A LGPD estabelece critérios claros sobre o que se entende por "dados pessoais". Dados pessoais, segundo a LGPD, são referentes a qualquer informação relacionada à pessoa natural ou identificável.

Esses dados, por sua vez, são tratados e utilizados. E o que é esse "tratamento de dados"?



DEFINIÇÃO:

Tratamento de dados é toda e qualquer operação realizada com dados pessoais, como as que se referem à coleta, classificação, utilização, acesso, reprodução, processamento, armazenamento, eliminação, controle da informação, entre outros.

Pelo que se pode perceber, esse tratamento de dados é algo bem complexo e abrangente. Mas você pode notar que existem papéis diferentes nos atores da LGPD. Existe a pessoa que possui os dados, a empresa que recebe, alguém que usa etc. Vamos ver mais detalhadamente quem são esses atores.

Papéis dos agentes vinculados pela LGPD

Conforme dissemos anteriormente, a LGPD prevê a existência de alguns atores relacionados aos dados. São eles:

- Titular.
- Controlador.
- Operador.
- Encarregado.

O titular, como o próprio nome sugere, é a pessoa física a quem se referem os dados pessoais. Somos nós, pessoas.

Por sua vez, o controlador é a pessoa física ou empresa que realiza a coleta desses dados pessoais e toma decisões de como eles serão tratados e com qual finalidade. Perceba que é um papel extremamente importante.

Esse controlador pode definir pessoas que operam com esses dados, ou os operadores. Eles, então, realizam o tratamento e o processamento desses dados sob ordens do controlador.

Por fim, temos o encarregado – esse ator é uma pessoa física indicada pelo controlador e atua como uma interface ou um canal de comunicação entre as partes, que são o controlador, os titulares e a autoridade nacional, que aqui no Brasil será a Autoridade Nacional de Processamento de Dados (ANPD), a qual ainda não foi criada.

Perceba que são várias definições importantes acerca de como e por quem esses dados serão tratados.

Essa lei tem período para entrar em vigor e produzir sanções. É o que veremos no item a seguir.

Vigência e sanções

A vigência da LGPD tem sido objeto de controvérsia até esse momento, pois tem acontecido uma série de movimentações no Congresso Nacional.

O mais provável é que a LGPD entre em vigor em agosto de 2020, com as sanções previstas para agosto de 2021. Por isso, as empresas têm se preocupado cada vez mais com isso, o que tem causado impacto nas organizações. A LGPD chegou para ficar, e as empresas precisarão mudar bastante a forma atual de gestão de dados para que possam se adequar à lei.

Como se preparar para implementar a LGPD

Fundamentalmente, são necessários oito passos prévios para se preparar para a implementação da LGPD. Por serem passos mais técnicos, voltados ao pessoal de infraestrutura e redes de computadores, colocaremos esses passos aqui de forma simplificada.

- Controle de acesso e senhas.
- Configuração segura dos equipamentos.
- Gerenciamento dos ativos da organização.
- Gestão de vulnerabilidades.
- Gestão de logs.
- Resposta a incidentes.
- Política de *backup*.
- Campanhas de conscientização.

Vamos explicar agora cada um deles.

A gestão de acesso e senhas é bem básica e direta: é necessário que os usuários tenham, cada um, seu *login* e sua senha para acessar os sistemas. É muito importante conceder o acesso correto ao usuário e retirar esse acesso quando o usuário não fizer mais parte da instituição. Ou seja, se a pessoa está na instituição, seu acesso só deve ser concedido nos itens ou sistemas realmente relacionados com o seu trabalho. E se a pessoa saiu da empresa, foi demitida ou pediu demissão, seu acesso deve ser cortado imediatamente. Imagine se, por exemplo, um ex-funcionário que ainda tem acesso ao sistema de gestão documental e, por vingança por ter sido demitido, resolve apagar todos os dados dos sistemas? Isso não pode acontecer sob nenhuma hipótese.

Por sua vez, a configuração segura de equipamentos também é muito importante. Os equipamentos devem ser configurados corretamente. Nada de usar programas piratas ou dar "jeitinho" para as coisas funcionarem. A única forma permitida para que os sistemas funcionem é a forma correta.

A questão do gerenciamento de ativos também é muito importante. Mas o que é um ativo? É qualquer bem que esteja à disposição da instituição. Nesse caso, o gerenciamento de ativos significa que o controlador sabe exatamente qual equipamento está com quem e sob quais condições ele opera.

A gestão de vulnerabilidades é outro ponto importantíssimo. Todo e qualquer problema de segurança deve ser evitado. A busca, identificação e eliminação de vulnerabilidades é uma dessas atividades. Sistema vulnerável é sistema inseguro. Sistema inseguro é um perigo.

Outro item muito importante e que, por incrível que pareça, muitas instituições não levam tanto a sério é a gestão de logs. O que é um log? É o registro de uma operação feita em um sistema. O sistema de logs guarda todos os registros das operações feitas. Com isso, podemos saber quem leu, quem alterou ou quem apagou uma dada informação, esse registro é muito importante em auditorias futuras.

A resposta a incidentes é também algo muito importante a se preocupar. Nenhuma empresa está a salvo de ter problemas. Nesse tipo de situação, a capacidade da empresa de se recuperar em caso de um incidente de segurança da informação é absolutamente fundamental. Devem existir mecanismos para que essa recuperação seja feita de forma segura e coerente.

Outra questão importantíssima e que também é negligenciada em muitas instituições é a política de *backup*. Por incrível que pareça, muitas empresas não guardam cópias dos seus dados em locais seguros. Com um *backup*, que é uma cópia dos dados, aumenta bastante a capacidade da instituição de se recuperar em caso de problemas nos dados.

Por fim, as campanhas de conscientização são absolutamente fundamentais para que as pessoas entendam a seriedade da lei e das consequências no caso de problemas de privacidade. Todo cuidado é pouco.

Você deve estar se perguntando: e o que a LGPD tem a ver com a gestão documental? Trataremos disso agora.

LGPD e a gestão documental

A LGPD tem fundamentos muito claros, expressos em seus vários artigos. Em particular, podemos citar, conforme seu artigo 2º:

- O respeito à privacidade.
- A inviolabilidade da intimidade, da honra e da imagem.
- Os direitos humanos, o livre desenvolvimento da personalidade, a dignidade e o exercício da cidadania pelas pessoas naturais.

Só esses fundamentos já se mostram bastante claros e ligados diretamente à gestão documental.

A privacidade dispensa maiores explicações: jamais um prontuário pode vaziar, por exemplo. No caso da intimidade, honra e imagem, é a mesma coisa. E os aspectos de direitos humanos são absolutamente fundamentais nessa gestão.

Além do mais, a lei define diversos conceitos de forma clara em seu artigo 5º, como (BRASIL, 2018):

- Dado pessoal – é a informação relacionada à pessoa natural identificada ou identificável, ou seja, informação pertinente a alguém.
- Dado pessoal sensível – é aquele dado pessoal que trata de origem racial ou étnica, convicção religiosa, opinião política, filiação a sindicato ou à organização de caráter religioso, filosófico ou político, dado referente à saúde ou à vida sexual, dado genético ou biométrico, quando vinculado a uma pessoa natural. Note que esse tipo de dado vai muito além de dados triviais como nome, CPF e RG. Por terem contextos que podem ser associados, esses dados são considerados sensíveis e demandam um cuidado especial.
- Titular – pessoa natural a quem se referem os dados pessoais que são objeto de tratamento. Esse conceito define, na prática, a pessoa sobre quem aqueles dados são armazenados.
- Controlador – pessoa natural ou jurídica, de direito público ou privado, a quem competem as decisões referentes ao tratamento de dados pessoais. É quem, na prática, passa a deter o domínio daqueles dados e os utiliza em suas operações.
- Operador – é a pessoa natural ou jurídica, de direito público ou privado, que realiza o tratamento de dados pessoais em nome do controlador. O operador trabalha sob coordenação e comando do controlador e, por isso, é corresponsável pela gestão.

- Tratamento – é toda operação realizada com dados pessoais, como as que se referem à coleta, produção, recepção, classificação, utilização, acesso, reprodução, transmissão, distribuição, processamento, arquivamento, armazenamento, eliminação, avaliação ou controle da informação, modificação, comunicação, transferência, difusão ou extração. Na prática, é tudo o que se faz com aqueles dados.
- Consentimento – manifestação livre, informada e inequívoca pela qual o titular concorda com o tratamento de seus dados pessoais para uma finalidade determinada. É a autorização expressa que o titular concede ao controlador para que ele tenha acesso e use os dados.
- Bloqueio – suspensão temporária de qualquer operação de tratamento, mediante guarda do dado pessoal ou do banco de dados. É, na prática, uma operação que proíbe temporariamente qualquer operação sobre aqueles dados.
- Eliminação – exclusão de dado ou de conjunto de dados armazenados em banco de dados, independentemente do procedimento empregado. Essa operação é o apagamento dos dados, que pode obedecer a diversas regras.
- Transferência internacional de dados – transferência de dados pessoais para país estrangeiro ou organismo internacional do qual o país seja membro. Os dados podem ser transferidos para outros países desde que sob as normas definidas em lei – isso pode acontecer, por exemplo, em redes sociais cujo banco de dados fique em outro país, como o Facebook.



SAIBA MAIS:

Para saber mais definições, acesse a lei pelo *link* a seguir: http://www.planalto.gov.br/ccivil_03/_Ato2015-2018/2018/Lei/L13709.htm.

O conceito de dado pessoal é o mais simples deles. Os dados sensíveis demandam um cuidado especial e normalmente existem diversos desses dados em prontuários ou históricos de pacientes. Imagine se esse tipo de dado acaba vazando porque na gestão documental não foram respeitados os cuidados com segurança da informação. Com certeza um grande problema, inclusive com repercussões jurídicas, pode ocorrer e trazer grandes transtornos. Por isso, é importante reforçar que a gestão documental deve ser feita de maneira profissional e cuidadosa, para que possamos usufruir da melhor forma das suas características e vantagens.



SAIBA MAIS:

Quer saber ainda mais? Então, veja como o DataSus está se preparando para se adequar à LGPD. Acesse o *link* a seguir: <https://datasus.saude.gov.br/datasus-adota-medidas-para-adequar-a-rnds-a-lei-de-protecao-de-dados/>



RESUMINDO:

Neste capítulo, conhecemos detalhes da Lei Geral de Proteção de Dados e sua relação com a gestão documental. Vimos os seus princípios, sua vigência e sua importância. Além disso, compreendemos como uma instituição pode se preparar para a LGPD.

A seguir, veremos os sistemas informacionais associados ao prontuário digital.

Sistemas informatizados para prontuários médicos



OBJETIVOS:

Vamos finalizar esta unidade falando sobre sistemas informatizados para prontuários médicos e tendências tecnológicas para a gestão documental. Vamos resgatar a definição de sistemas de informação para a saúde, da Organização Mundial da Saúde (OMS), e abordaremos os prontuários e as tendências para concluir com chave de ouro a nossa disciplina.

Sistemas de informação para saúde

Conforme definição da OMS, disponível no *site* da Universidade Federal de Santa Catarina, um sistema em informação em saúde (SIS) é:

Um conjunto de componentes que atuam de forma integrada por meio de mecanismos de coleta, processamento, análise e transmissão da informação necessária e oportuna para implementar processos de decisões no Sistema de Saúde. (OMS, 1981)

O prontuário eletrônico é um desses sistemas, o qual abordaremos a seguir.

Prontuário eletrônico

Na unidade 1, falamos do prontuário eletrônico, mas não entramos em detalhes. A hora de fazer isso é agora.

Conforme o *site* do DATASUS, a Resolução CFM nº 1.638/2002 define prontuário eletrônico como "o conjunto de informações assistenciais,

oriundas de atendimentos de saúde, em diferentes âmbitos (ambulatorial ou internação), registradas de forma eletrônica".

Fica fácil perceber que esse tipo de sistema é cada vez mais utilizado e demanda uso de computadores e infraestrutura de banco de dados e de redes. O DATASUS tem o seu próprio sistema, o prontuário eletrônico do cidadão (PEC).

O PEP é conceituado por Pinto (2006, p. 37) como:

Um documento eletrônico constituído pelo conjunto de informações concernentes a uma pessoa doente, aos tratamentos e cuidados a ela dispensados, bem como à gestão e ao fluxo de informação e comunicação atinentes ao paciente das organizações da saúde.

Figura 7: Veja a imagem a seguir de um sistema de prontuário eletrônico disponível em [aps.saude.gov.br](https://saude.gov.br):

A imagem mostra a interface do sistema de prontuário eletrônico (PEC) do DATASUS. No topo, há uma barra de navegação com o caminho: PEC > Atendimentos > Prontuário > Folha de rosto. Abaixo, o perfil do paciente "MOISES PEDRO" é exibido, com idade de 30 anos e 6 meses e 23 dias, masculino, solteiro. À esquerda, há uma barra lateral com ícones e links para: FOLHA DE ROSTO (selecionado), SOAP, PROBLEMAS / CONDIÇÕES E ALERGIAS, ACOMPANHAMENTO, ANTECEDENTES, HISTÓRICO, DADOS CADASTRAIS e FINALIZAÇÃO DO ATENDIMENTO. O formulário principal à direita contém campos para: ESCUTA INICIAL (com o texto "Não foi realizada escuta inicial."), ÚLTIMOS CONTATOS (com "Nenhuma avaliação realizada anteriormente."), PROBLEMAS / CONDIÇÕES (com "Nenhum problema cadastrado."), ALERGIAS / REAÇÕES ADVERSAS (com "Nenhuma alergia cadastrada."), MEDICAMENTOS ATIVOS (com "Nenhum medicamento ativo prescrito para o cidadão.") e LEMBRETES (com "Nenhum lembrete cadastrado."). No rodapé, há dois botões: "Cancelar atendimento" e "Finalizar atendimento".

Fonte: Elaborado pelo autor.

Conforme dissemos anteriormente, o prontuário eletrônico traz um grande salto em termos de qualidade, além de muitas vantagens em relação ao prontuário original. Traz melhor legibilidade, por evitar

os problemas relacionados à caligrafia e registra, com fonte escalável (em alguns casos, permite inclusive a alteração do tipo de fonte e seu tamanho), as informações relevantes. O mesmo acontece com a sua impressão, que é feita com qualidade e não dá margem a interpretações sobre o que está escrito. Além disso, garante melhor disponibilidade para acesso remoto – uma vez que está disponível na rede de computadores de forma digital, ou seja, o prontuário eletrônico pode ser acessado por um profissional que não esteja presente na unidade hospitalar.

Se o sistema permitir (como no caso do e-SUS hospitalar), esse tipo de disponibilidade facilita muito o intercâmbio de informações entre especialistas para que possam decidir qual a melhor abordagem em um dado caso, mesmo se o profissional não estiver naquela unidade hospitalar.

Ele também facilita o acesso simultâneo, pois se o prontuário está na rede então pode ser acessado por mais de um profissional ao mesmo tempo – e isso traz um grande ganho de eficiência e produtividade. Garante também segurança de acesso por conter definições de segurança e atribuição de perfis de acesso com usuário e senha, evitando que os dados sejam acessados de forma indevida.

Também garante confidencialidade dos dados do paciente, uma vez que foi garantida a segurança. A confidencialidade dos dados do paciente, dessa forma, pode ser conseguida sem maiores dificuldades. É importante salientar que a confidencialidade pode admitir a possibilidade de tratar alguns dados como restritos ou secretos, de acordo com a criticidade da informação.

Também apresenta uma importante multiplicidade de formas de apresentação – por ser digital e permitir o uso de técnicas de acessibilidade, o PEP pode ser apresentado de em vários dispositivos, como computadores, *smartphones*, *tablets*, enfim, em diversas maneiras e plataformas, podendo inclusive ser acessado simultaneamente em vários desses meios.

Outra característica importantíssima é a melhor integração com outros sistemas computacionais – os sistemas de PEP fornecem dados

para outros sistemas, para gerenciamento, geração de dados estatísticos e qualquer informação considerada significativa na gestão de saúde.

Além disso, o PEP viabiliza apoio ao desenvolvimento de pesquisas – é fácil perceber que ele gera diversos dados que podem ser utilizados por outros sistemas, incluindo sistemas de busca, de modo que esses dados possam ser indexados, permitindo, por exemplo, que sejam usados em pesquisas científicas ou por sistemas de rastreamento com robô, com coletas de dados xml para consumo em sistemas de contabilização e consolidação de dados, com a finalidade de melhorar a difusão de informações e aumentar o conhecimento sobre as áreas ligadas aos cuidados ao paciente. Dessa forma, o volume de dados gerado é um importante repositório que pode ser utilizado para o desenvolvimento constante da área de pesquisa, que muito se beneficia desses dados.

São muitas características, não é? Vamos continuar.

O PEP também melhora muito os relatórios – o prontuário eletrônico do paciente é utilizado como base para a geração de relatórios diversos, sintéticos ou analíticos, com os mais diversos níveis de detalhe. Ele garante, ainda, dados constantemente atualizados – é bem mais fácil atualizar um prontuário eletrônico do que um prontuário de papel, em função da sua portabilidade, acessibilidade e melhor difusão.

Mas nem tudo é perfeito...

Como também fizemos anteriormente, vamos detalhar agora as desvantagens do uso do PEP, ao menos no início. Ressaltamos que, com o passar do tempo, as vantagens do uso do PEP superam em larga margem as desvantagens.

A primeira das desvantagens do PEP é o alto custo de implantação. De toda forma, seu custo deve ser visto como investimento necessário, pois a informatização é inevitável e absolutamente necessária. Os custos logísticos de implantação também são relevantes. Sempre é necessário treinar usuários, os processos precisarão ser modificados, questões estruturais precisarão ser equacionadas, além de diversos aspectos relacionados a questões técnicas, como *software* e *hardware*.

Esse processo sempre é complicado, pois nem sempre os usuários são receptivos às mudanças.

De toda forma, o PEP veio para ficar e é um grande passo na melhoria do fluxo informacional nas instituições. As tendências tecnológicas da gestão documental e dos sistemas informacionais nos ambientes hospitalares em geral são de uma integração cada vez maior dos mais diversos dispositivos e recursos. A telepresença, a inteligência artificial, a inteligência de negócio e os grandes repositórios de dados serão cada vez mais utilizados.

O uso de recursos informacionais só tende a crescer, com as máquinas cada vez mais integradas e interligadas, tornando o mundo hospitalar ainda mais digitalizado e informatizado.

O próprio DATASUS, que trata do desenvolvimento de sistemas hospitalares para o ministério da saúde, tem diversos sistemas que integram desde a gestão hospitalar, a gestão operacional do dia a dia até a gestão documental.

A informática veio para ficar, e a gestão documental aproveita e utiliza, da melhor forma, as vantagens da digitalização.



SAIBA MAIS:

Quer conhecer o DATASUS? Então, visite o site: www.datasus.saude.gov.br.

Com isso, chegamos ao fim da nossa unidade e da nossa disciplina.



RESUMINDO:

Estamos chegando ao fim desta disciplina. Nela, vimos importantes conceitos da gestão documental. Conhecemos diversos conceitos da arquivologia, da terminologia arquivística, dos sistemas associados e de sua legislação.

REFERÊNCIAS

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. NBR ISO/IEC 27002:2005: Tecnologia da Informação – Técnicas de segurança – Código de prática para a gestão da segurança da informação. Rio de Janeiro, 2005.

BRASIL, PAÍS DIGITAL. Ransomware – Sequestro de Dados. Segurança e cidadania no mundo digital. Disponível em: <https://brasilpaisdigital.com.br/seguranca-e-cidadania-no-mundo-digital/ransomware/#:~:text=RANSOMWARE%20%E2%80%93%20Sequestro%20de%20Dados,armazenados%20no%20seu%20computador%2C%20dispositivo.&text=Esse%20tipo%20de%20ataque%20pode,m%C3%B3veis%20e%20equipamentos%20de%20rede>. Acesso em: 24 jul. 2020.

BRASIL. Lei nº 12.682, de 09 de julho de 2012. Lei Geral de Proteção de Dados Pessoais (LGPD). Disponível em: http://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/L13709.htm. Acesso em: 23 jul. 2020.

BRASIL. Lei nº 8.159, de 8 de janeiro de 1991. Dispõe sobre a política nacional de arquivos públicos e privados e dá outras providências. Disponível em: http://www.planalto.gov.br/ccivil_03/Leis/L8159.htm. Acesso em: 25 maio 2020.

BRASIL. Ministério da Saúde. O Sistema e-SUS HOSPITALAR. DATASUS. Disponível em: <http://www2.datasus.gov.br/ESUSHOSP/>. Acesso em: 24 jul. 2020.

CARVALHO, M. M et al., Gestão da qualidade: teoria e casos. Rio de Janeiro: Elsevier, 2005.

CERT.BR. Cartilha de Segurança para Internet. Versão 3.1/CERT.br. São Paulo: Comitê Gestor da Internet no Brasil, 2006. Disponível em: http://www.campinas.sp.gov.br/arquivos/cartilha_seguranca_internet.pdf. Acesso em: 24 jul. 2020.

CONARQ; CTDE. Glossário: Documentos Arquivísticos Digitais. 2014. 6ª versão. Disponível em: http://www.conarq.arquivonacional.gov.br/images/ctde/Glossario/2014ctdeglossario_v6_public.pdf. Acesso em: 25 maio 2020.

DRUCKER, P. F. A administração na próxima sociedade. Tradução de Nivaldo Montigelli Jr. São Paulo: Nobel, 2002.

FALCONI V. C. TQC – Controle da Qualidade Total no estilo japonês. Belo Horizonte, MG: Editora de Desenvolvimento Gerencial, 1999.

GIANESI, I. G. N.; CORRÊA, H. L. Administração estratégia de serviços: operações para a satisfação do cliente. São Paulo: Atlas, 1994.

JURAN, J. M.; Controle da qualidade: conceitos, políticas e filosofia da qualidade. São Paulo: McGraw-Hill: Makron, 1991-1993. 8v.

MOURA E. C. As sete ferramentas gerenciais da qualidade – implementando a melhoria contínua com maior eficácia. São Paulo: Makron Books, 1994.

OLIVEIRA, D. P. R. Planejamento estratégico, conceitos metodologia práticas. 22. ed. São Paulo: Atlas. 2005.

ORGANIZAÇÃO NACIONAL DE ACREDITAÇÃO. O que é acreditação? Disponível em: <https://www.ona.org.br/acreditacao/o-que-e-acreditacao>. Acesso em: 24 jul. 2020.

PINTO, V. B. Prontuário eletrônico do paciente: documento técnico e informação e comunicação o domínio da saúde. Enc. Bibli.: R. Eletr. Bibliotecon. Ci. Inf., Florianópolis, n. 21, 1º sem. 2006.

PNASS. Relação de documentos necessários para comprovação dos itens de verificação – estabelecimentos hospitalares. 2015. Disponível em: <http://portalarquivos.saude.gov.br/images/pdf/2015/junho/02/RELA----O-DE-DOCUMENTOS--ESTABELECIMENTOS-HOSPITALARES.pdf>. Acesso em: 25 maio 2020.

SALVADOR, V. F. M.; ALMEIDA FILHO, F. G. V. Aspectos Éticos e de Segurança do Prontuário Eletrônico do Paciente. In: II JORNADA DO CONHECIMENTO E DA TECNOLOGIA. Anais [...]. Marília: UNIVEM, ago. 2005, 8p.

UNIVERSIDADE FEDERAL DE SANTA CATARINA. Epidemiologia Sistema de Informações em Saúde (SIS). Especialização Multiprofissional na Atenção Básica. Organização Mundial de Saúde. 1981.

Gestão de Serviços de Documentação Hospitalar

Ricardo Baudel